GRC Fundamentals Assessment

Nexus Financial Services | Governance, Risk & Compliance

Prepared by: Steven Dairo	**Role:** Junior GRC Analyst
Date: 26 October 2026	**Case study:** Nexus Financial Services

1. Definitions of Governance, Risk, and Compliance

Governance: Governance is how an organization is directed and controlled. It establishes who is responsible for making decisions, which policies must be followed, and how leaders ensure that the organization operates consistently and responsibly.

Risk Management: Risk management is the process of identifying events or decisions that could prevent an organization from achieving its objectives, assessing how likely and serious they could be, and deciding how to reduce or manage their impact.

Compliance: Compliance means making sure the organization follows the laws, regulations, standards, contractual requirements, and internal policies that apply to its activities. This includes knowing what the obligations are, assigning responsibility, and tracking deadlines and evidence.

2. Three Issues Identified in the Case Study

Issue observed	GRC category	Why it matters
1. No formal policy approval or enforcement process. Nexus does not have a consistent process to create, approve, communicate, review, and enforce company policies.	**Governance**	Employees may be unsure which policies are current, who owns them, or how they should be applied. This can lead to inconsistent decisions and practices.
2. No standard risk assessment process. The company lacks a consistent method for assessing risk before important business decisions are made.	**Risk Management**	Important risks may be overlooked or assessed inconsistently, making it harder for decision-makers to prioritize and address them.
3. No assigned owner for regulatory requirements and deadlines. No designated person is responsible for tracking regulatory obligations and their due dates.	**Compliance**	Requirements may be missed, deadlines may be overlooked, and management may lack a clear view of compliance status and supporting evidence.

3. Recommendation to Improve the GRC Programme

Recommendation: Establish a formal GRC framework with clearly assigned responsibilities. Nexus should introduce one coordinated framework that defines how policies are managed, how risks are assessed, and how regulatory obligations are monitored. The framework should include a policy approval and review process, a standard risk assessment method using likelihood and impact, and a compliance register that records each obligation, its owner, deadline, status, and supporting evidence. Management should review and receive regular updates on significant risks and compliance issues.

Expected benefit: This approach would clarify accountability, support more consistent decisions, help the company identify and manage risks earlier, and reduce the chance of overlooking regulatory obligations.

Conclusion

The Nexus case study shows that the company’s growth has outpaced its existing governance and control processes. By establishing a formal GRC framework, Nexus can strengthen policy management, make risk assessment more consistent, and improve oversight of regulatory responsibilities.